



RISKSIM

Simulation walkthrough

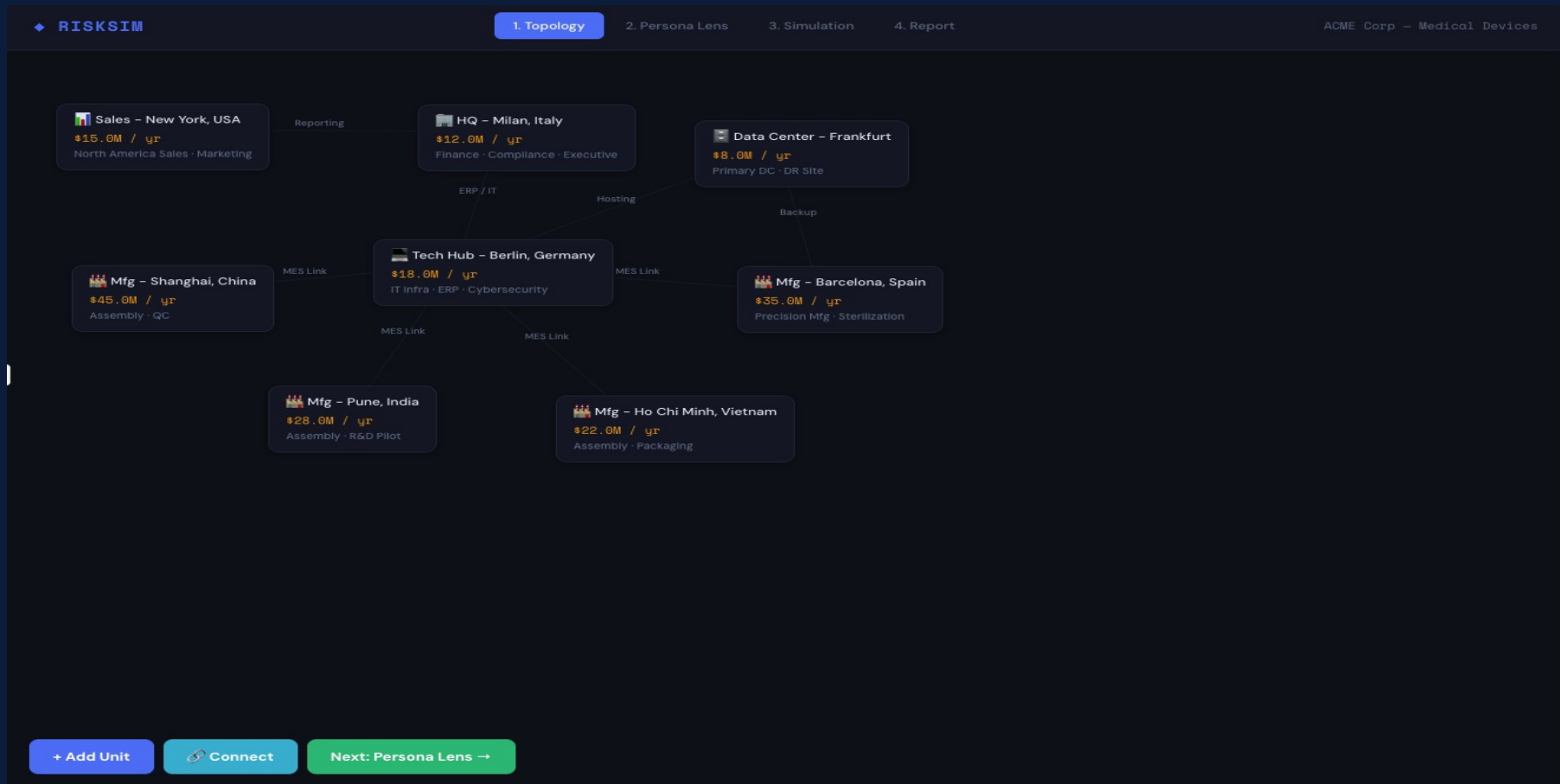
Operation Steel Viper — ACME Corp, Medical Devices

A compound ransomware scenario across a global manufacturing topology

TOPOLOGY

Define the organizational topology

Map business units, infrastructure, dependencies, and financial exposure across all sites



CISO risk exposure map

8 attack surface nodes, 3 critical dependencies — Berlin Tech Hub identified as single point of failure

◆ RISKSIM

1. Topology

2. Persona Lens

3. Simulation

4. Report

ACME Corp — Medical Devices

CEO View

CTO View

CISO View

🛡️ CISO: Risk Exposure Map

Risk Score: HIGH | 8 attack surface nodes | 3 critical dependencies

🏢 HQ — Milan, Italy

LOW

Dependent on tech hub

🏭 Mfg — Shanghai, China

MEDIUM

Dependent on tech hub

🏭 Mfg — Pune, India

MEDIUM

Dependent on tech hub

🏭 Mfg — Ho Chi Minh, Vietnam

MEDIUM

Dependent on tech hub

🏭 Mfg — Barcelona, Spain

MEDIUM

Dependent on tech hub

🏢 Tech Hub — Berlin, Germany

CRITICAL

Single point of failure for MES

🏢 Data Center — Frankfurt

HIGH

Contains PII / PHI data

🏢 Sales — New York, USA

LOW

Dependent on tech hub

← Back

🚧 Decision Mode — Play the Scenario

📅 BCP Test — Stress-Test Your Plan

Review auto-generated business continuity plan

BCP generated from topology — RTO: 8h, RPO: 4h, Max Tolerable Downtime: 72h — benchmarked against JLR attack

BCP TEST

LOSS w/ BCP: \$0.0M



BCP Stress Test — Review Your Plan

AUTO-GENERATED BCP

ACME Corp — Business Continuity Plan v1.0

RTO: 8h | RPO: 4h | Max Tolerable Downtime: 72h

This BCP was generated based on your org topology. We'll now run the Operation Steel Viper scenario against each section and score how well your plan holds up — compared to lessons learned from the real JLR ransomware attack (£1.9B impact).

1. Detection & Alerting

Target: within 1h of incident

- SOC monitors SIEM alerts 24/7 — escalation within 15 minutes of anomaly detection
- Automated isolation triggers for Tech Hub, Data Center if ransomware signatures detected
- CISO notified within 30 minutes; CEO within 1 hour of confirmed incident
- Activate incident bridge call with IT leads from all locations

2. Containment & Isolation

Target: within 2h of incident

- Sever MES links between Tech Hub and manufacturing plants (Mfg, Mfg, Mfg, Mfg)
- Disable all vendor/third-party VPN access immediately
- Isolate ERP system and switch to manual order processing
- Quarantine Data Center and activate network segmentation protocols
- Preserve forensic evidence — do NOT wipe or reboot compromised systems

3. Communication Protocol

Target: within 3h of incident

←
Abort

▶ Begin Stress Test

BCP TEST

Event 1 of 5 — T+0h: Initial breach detected

Berlin Tech Hub SIEM flags lateral movement. Infostealer harvests vendor VPN credentials. Testing: Detection and Alerting (72/100)

RISKSIM

1. Topology

2. Persona Lens

3. BCP Test

4. Report

ACME Corp — Medical Devices

BCP TEST

LOSS w/ BCP: \$0.2M

T+0h



BCP Stress Test — Event 1 of 5

Score: 72%

⚠️ T+0h: INITIAL BREACH DETECTED

Your Berlin Tech Hub SIEM flags unusual lateral movement at 02:47 AM local time. An infostealer malware has harvested credentials from a third-party vendor's VPN session — the same technique used in the JLR HELLCAT breach earlier this year. The attacker is already inside your network, moving toward your MES systems.

Testing: 1. Detection & Alerting

72/100

- ✅ SOC alerting is defined with 15-minute SLA — meets industry benchmark
- ❌ No mention of after-hours escalation procedure — breach occurred at 02:47 AM
- ✅ CISO notification chain is documented
- ❌ No automated kill-switch for vendor VPN sessions — JLR's breach exploited this exact gap

Loss with BCP: \$0.2M

Loss without BCP: \$1.5M

BCP saved: \$1.3M

⏪
Abort

▶ Next Event: T+2h

Event 2 of 5 — T+2h: Ransomware propagation

ERP encryption begins. MES links showing anomalous traffic toward manufacturing plants. Testing: Containment and Isolation (65/100)

RISKSIM

1. Topology

2. Persona Lens

3. BCP Test

4. Report

ACME Corp — Medical Devices

BCP TEST

LOSS w/ BCP: \$3.4M

T+2h



BCP Stress Test — Event 2 of 5

Score: 69%

credentials from a third-party vendor's VPN session — the same technique used in the JLR HELLCAT breach earlier this year. The attacker is already inside your network, moving toward your MES systems.

Testing: 1. Detection & Alerting

72/100

- ✓ SOC alerting is defined with 15-minute SLA — meets industry benchmark
- ✗ No mention of after-hours escalation procedure — breach occurred at 02:47 AM
- ✓ CISO notification chain is documented
- ✗ No automated kill-switch for vendor VPN sessions — JLR's breach exploited this exact gap

Loss with BCP: \$0.2M Loss without BCP: \$1.5M BCP saved: \$1.3M

⚠ T+2h: RANSOMWARE PROPAGATION

The ransomware has begun encrypting ERP database tables. Your MES links to Shanghai and Pune are showing anomalous traffic patterns consistent with lateral movement. The attackers appear to have studied your network topology — they're targeting the exact connections between your Tech Hub and manufacturing plants. This mirrors the JLR attack where poor network segmentation allowed IT-to-OT crossover.

Testing: 2. Containment & Isolation

65/100

- ✓ MES link severance procedure is documented — critical for stopping lateral movement
- ✓ Vendor VPN shutdown is specified — would have blocked initial vector
- ✗ No IT/OT segmentation testing documented — JLR's £1.9B loss was driven by IT-OT crossover
- ✗ Forensic evidence preservation step is good, but no designated forensics lead assigned
- ✗ Manual order processing fallback lacks detail — how long can plants operate without ERP?

Loss with BCP: \$3.2M Loss without BCP: \$12.0M BCP saved: \$8.8M

←
Abort

▶ Next Event: T+6h

Event 3 of 5 — T+6h: Production halt and supply chain cascade

All four manufacturing plants offline. Suppliers sending workers home. Loss with BCP: \$11.9M. Testing: Communication Protocol (78/100)

RISKSIM

1. Topology

2. Persona Lens

3. BCP Test

4. Report

ACME Corp — Medical Devices

BCP TEST LOSS w/ BCP: \$11.9M T+6h



BCP Stress Test — Event 3 of 5

Score: 72%

Segmentation allowed IT-to-OT crossover.

Testing: 2. Containment & Isolation

65/100

- ✓ MES link severance procedure is documented — critical for stopping lateral movement
- ✓ Vendor VPN shutdown is specified — would have blocked initial vector
- ✗ No IT/OT segmentation testing documented — JLR's £1.9B loss was driven by IT-OT crossover
- ✗ Forensic evidence preservation step is good, but no designated forensics lead assigned
- ✗ Manual order processing fallback lacks detail — how long can plants operate without ERP?

Loss with BCP: \$3.2M Loss without BCP: \$12.0M BCP saved: \$8.8M

⚠ T+6H: PRODUCTION HALT & SUPPLY CHAIN CASCADE

All four manufacturing plants are now offline. Shanghai and Pune were hit directly; Vietnam and Barcelona were proactively shut down per containment protocol. Your supply chain partners are calling — they can't access ordering systems. One smaller supplier has already sent workers home. In the JLR incident, this cascading supply chain disruption eventually threatened over 100,000 jobs and cost suppliers millions in their own right.

Testing: 3. Communication Protocol

78/100

- ✓ Out-of-band communication channel specified — critical when email systems are compromised
- ✓ Supplier notification within 4 hours is aggressive and appropriate
- ✓ Regulatory notification within 72 hours meets GDPR requirements
- ✗ No government liaison mentioned — JLR required NCSC and law enforcement coordination
- ✗ Missing: supply chain financial support framework — JLR suppliers laid off hundreds of workers

Loss with BCP: \$8.5M Loss without BCP: \$28.0M BCP saved: \$19.5M

←
Abort

▶ Next Event: T+24h

Event 4 of 5 — T+24h: Recovery decision point

Attackers leak data on dark web. Barcelona says 48h to restart on manual. Testing: Recovery and Restoration (58/100)

BCP TEST

LOSS w/ BCP: \$26.9M

T+24h



BCP Stress Test — Event 4 of 5

Score: 68%

Testing: 3. Communication Protocol

78/100

- ✓ Out-of-band communication channel specified — critical when email systems are compromised
- ✓ Supplier notification within 4 hours is aggressive and appropriate
- ✓ Regulatory notification within 72 hours meets GDPR requirements
- ✗ No government liaison mentioned — JLR required NCSC and law enforcement coordination
- ✗ Missing: supply chain financial support framework — JLR suppliers laid off hundreds of workers

Loss with BCP: \$8.5M Loss without BCP: \$28.0M BCP saved: \$19.5M

⚠ T+24H: RECOVERY DECISION POINT

It's been 24 hours. Your DR site in Frankfurt has partial ERP functionality restored. The attackers have posted a ransom demand and leaked sample data on a dark web forum — including employee records and development logs. The board is asking when production resumes. Your Barcelona plant manager says they could restart on manual systems within 48 hours, but without MES validation, product quality can't be certified for medical device regulatory compliance.

Testing: 4. Recovery & Restoration

58/100

- ✓ DR site failover is documented — Frankfurt activation is realistic
- ✗ 8-hour RTO is unrealistic for this scale of attack — JLR took 4+ weeks to restart production
- ✗ No mention of regulatory re-certification for medical devices after system rebuild
- ✓ Phased reconnection order (DC → ERP → MES → VPN) is sound
- ✗ Missing: criteria for deciding whether to pay ransom vs. rebuild from backups
- ✗ No data breach response plan for leaked employee PII and source code

Loss with BCP: \$15.0M Loss without BCP: \$52.0M BCP saved: \$37.0M

←
Abort

▶ Next Event: T+72h

Event 5 of 5 — T+72h: Aftermath and financial reckoning

Production halted across all sites. OT integrity checks reveal deeper compromise. Testing: Financial Impact Management (70/100)

RISKSIM

1. Topology

2. Persona Lens

3. BCP Test

4. Report

ACME Corp — Medical Devices

BCP TEST

LOSS w/ BCP: \$48.9M

T+72h



BCP Stress Test — Event 5 of 5

Score: 69%

Testing: 4. Recovery & Restoration

58/100

- ✓ DR site failover is documented — Frankfurt activation is realistic
- ✗ 8-hour RTO is unrealistic for this scale of attack — JLR took 4+ weeks to restart production
- ✗ No mention of regulatory re-certification for medical devices after system rebuild
- ✓ Phased reconnection order (DC → ERP → MES → VPN) is sound
- ✗ Missing: criteria for deciding whether to pay ransom vs. rebuild from backups
- ✗ No data breach response plan for leaked employee PII and source code

Loss with BCP: \$15.0M Loss without BCP: \$52.0M BCP saved: \$37.0M

⚠ T+72H: AFTERMATH & FINANCIAL RECKONING

Three days in. Production remains halted across all sites. Your phased restart plan is behind schedule — the OT integrity checks revealed deeper compromise than expected. The financial impact is mounting: direct production losses, supplier compensation claims, potential regulatory fines for the data breach, and reputational damage with key healthcare customers. Analysts are comparing your situation to JLR's £1.9 billion economic impact. Your cyber insurance carrier is requesting documentation.

Testing: 5. Financial Impact Management

70/100

- ✓ Cyber insurance activation is documented — critical for loss recovery
- ✓ Daily production loss estimation methodology is sound
- ✗ No pre-negotiated incident response retainer — delays forensics and legal response
- ✗ Supply chain compensation framework lacks specific triggers and thresholds
- ✓ Cost documentation process will support insurance claims
- ✗ Missing: reputational damage mitigation plan for healthcare/regulated customers

Loss with BCP: \$22.0M Loss without BCP: \$85.0M BCP saved: \$63.0M

←
Abort

Generate Report

BCP assessment — overall score and section gaps

BCP Grade: B — Loss with BCP: \$48.9M vs. Loss without: \$178.5M — BCP saved \$129.6M across 72 simulated hours

BCP STRESS TEST REPORT — CLASSIFIED

Operation Steel Viper — BCP Assessment

BCP tested across 5 scenario events over 72 simulated hours

LOSS w/ BCP

\$48.9M

LOSS w/o BCP

\$178.5M

BCP SAVED

\$129.6M

TIME SPAN

72h

BCP GRADE

B

BCP Section Scores

1. Detection & Alerting

72%

GAPS IDENTIFIED:

- No mention of after-hours escalation procedure — breach occurred at 02:47 AM
- No automated kill-switch for vendor VPN sessions — JLR's breach exploited this exact gap

2. Containment & Isolation

65%

GAPS IDENTIFIED:

- No IT/OT segmentation testing documented — JLR's £1.9B loss was driven by IT-OT crossover
- Forensic evidence preservation step is good, but no designated forensics lead assigned
- Manual order processing fallback lacks detail — how long can plants operate without ERP?

3. Communication Protocol

78%

GAPS IDENTIFIED:

- No government liaison mentioned — JLR required NCSC and law enforcement coordination
- Missing: supply chain financial support framework — JLR suppliers laid off hundreds of workers

Key recommendations from stress test

Close IT/OT segmentation gap, revise RTO assumptions, add regulatory re-certification, establish ransom decision framework

4. Recovery & Restoration

58%

GAPS IDENTIFIED:

- 8-hour RTO is unrealistic for this scale of attack — JLR took 4+ weeks to restart production
- No mention of regulatory re-certification for medical devices after system rebuild
- Missing: criteria for deciding whether to pay ransom vs. rebuild from backups
- No data breach response plan for leaked employee PII and source code

5. Financial Impact Management

70%

GAPS IDENTIFIED:

- No pre-negotiated incident response retainer — delays forensics and legal response
- Supply chain compensation framework lacks specific triggers and thresholds
- Missing: reputational damage mitigation plan for healthcare/regulated customers

Key Recommendations

- 1. Close IT/OT Segmentation Gap:** Your BCP assumes containment can prevent lateral movement to OT systems, but no segmentation testing is documented. The JLR attack's £1.9B impact was driven primarily by IT-to-OT crossover.
- 2. Revise RTO Assumptions:** Your 8-hour RTO is unrealistic for a full-scale ransomware attack. JLR took 4+ weeks to restore production. Model a phased RTO: 24h for DR failover, 1-2 weeks for partial production, 4-6 weeks for full operations.
- 3. Add Regulatory Re-certification:** As a medical device manufacturer, any system rebuild requires re-validation for regulatory compliance. This critical step is missing from your recovery plan.
- 4. Government & Supply Chain Coordination:** JLR required NCSC involvement and government support. Your BCP should include pre-established relationships with national cyber security agencies and a supply chain financial support framework.
- 5. Ransom Decision Framework:** Your BCP has no criteria for the pay-vs-rebuild decision. Document this in advance with legal counsel — making this decision under pressure leads to worse outcomes.

SIMULATION

Round 1 of 5 — CISO first decision

Active encryption in progress. Choose: emergency segmentation, surgical containment, failover to Frankfurt, or pay ransom (\$2.3M)

RISKSIM

1. Topology

2. Persona Lens

3. Simulation

4. Report

ACME Corp — Medical Devices

LOSS: \$1.05M T+1h ROUND 1/5



Simulation — CISO Decisions

minutes before critical systems start locking up.

****IMMEDIATE THREAT STATUS:****

- ****Berlin Tech Hub****: Active encryption in progress
- ****ERP System****: Partial compromise detected
- ****MES Links****: Malware propagating toward all 4 manufacturing sites
- ****Data Center Frankfurt****: Still clean, but connected

YOU MUST DECIDE NOW:

****What is your decision, CISO?****

CHOOSE YOUR ACTION:

1. ****Emergency network segmentation – isolate Berlin and sever all MES links immediately**** – Stops the spread but manufacturing plants go dark and lose production visibility for hours
2. ****Activate incident response team and attempt surgical containment while systems stay online**** – Keeps operations running but risks ransomware reaching manufacturing floors within minutes
3. ****Immediate failover to Frankfurt DR site and rebuild Berlin from backup**** – Clean slate approach but 4–6 hour recovery window and potential data loss from last backup point
4. ****Pay the ransom demand (initial contact shows \$2.3M Bitcoin demand) to get decryption keys**** – Fastest restoration path but funds criminal enterprise and no guarantee of full recovery

← Abort Simulation

SIMULATION

Round 3 of 5 — Cascading manufacturing failure

SOC isolates Berlin but manufacturing halts across 4 continents. Total loss: \$4.87M. Barcelona as pivot hub vs. emergency cloud MES

RISKSIM

1. Topology

2. Persona Lens

3. Simulation

4. Report

ACME Corp — Medical Devices

LOSS: \$4.87M

T+7h

ROUND 3/5



Simulation — CISO Decisions

Your SOC team yanks network cables and kills VPN tunnels to Berlin within minutes—the infected systems go dark, but so does your entire manufacturing execution system across four continents. Production lines in Shanghai, Pune, Ho Chi Minh, and Barcelona grind to a halt as operators lose visibility into work orders, quality checks, and inventory tracking. The Frankfurt DR site is clean, but without Berlin's middleware layer, it's an island—your factories are flying blind.

NEWLY IMPACTED NODES:

- Mfg - Shanghai, China (manufacturing) - ****OFFLINE****
- Mfg - Pune, India (manufacturing) - ****OFFLINE****
- Mfg - Ho Chi Minh, Vietnam (manufacturing) - ****OFFLINE****
- Mfg - Barcelona, Spain (manufacturing) - ****OFFLINE****

****ADDITIONAL LOSS:**** \$2.85M (manufacturing downtime across all sites: ~2.5 hours @ combined \$1.14M/hr)

****TOTAL LOSS:**** \$6.12M

****HOURS ELAPSED:**** 6.5

****STATUS:**** All manufacturing HALTED | Berlin isolated | Ransomware contained

CHOOSE YOUR ACTION:

- **Emergency manual operations at factories**** - Paper-based production for critical orders while you rebuild, loses efficiency but keeps revenue flowing
- **Rapid point-to-point VPN from Frankfurt to each factory**** - Bypass Berlin entirely with temporary direct connections, risky configuration but faster than full rebuild
- **Bring Barcelona online first as pivot hub**** - Use Spain's clean backup connection to Frankfurt to cascade MES access to Asian sites, creates single point of failure
- **Pay the ransom (\$850K in Bitcoin)**** - Attackers promise decryption keys within 2 hours, could restore Berlin quickly but no guarantees and sets precedent

← Abort Simulation

SIMULATION

Round 4 of 5 — Barcelona at 87% capacity

Makeshift architecture holding by a thread. Shanghai plant demands Berlin restoration. Board wants briefing in 2 hours. Total loss: \$8.68M

RISKSIM

1. Topology

2. Persona Lens

3. Simulation

4. Report

ACME Corp — Medical Devices

LOSS: \$8.68M

T+8h

ROUND 4/5



Simulation — CISO Decisions

****NEWLY IMPACTED NODES:****

- ****Mfg — Barcelona, Spain**** (degraded performance, now critical single point of failure)
- ****Mfg — Ho Chi Minh, Vietnam**** (assembly disruptions due to latency)

****FINANCIAL IMPACT:**** +\$1.2M additional loss (Ho Chi Minh downtime, Barcelona productivity drop, emergency network engineering costs)

****TIME ELAPSED:**** +3 hours (now 10 hours total)

****TOTAL LOSS SO FAR:**** \$6.07M

ROUND 4 OF 5 — NEXT DECISION

Your makeshift architecture is holding by a thread. Barcelona's network team warns they're at 87% bandwidth capacity. Shanghai's plant manager is demanding direct Berlin restoration. The Board wants a briefing in 2 hours.

CHOOSE YOUR ACTION:

- **Throttle non-critical traffic and implement QoS prioritization**** - Keeps cascade alive longer but kills BI/reporting access for Finance and Sales
- **Spin up emergency cloud MES gateway in AWS Frankfurt region**** - 6-8 hour deployment, \$180K setup cost, untested architecture under pressure
- **Restore Berlin core systems in degraded mode (partial services only)**** - Faster than full rebuild but means accepting some compromised infrastructure may still be active
- **Declare major incident and halt all Asian manufacturing until Berlin fully restored**** - Stops the bleeding but \$2-3M per day in lost production and customer penalties

← Abort Simulation

Round 5 of 5 — Final decision

VP Finance demands ERP access. Manufacturing stable but fragile. Attacker foothold still in Berlin. Total loss: \$13.54M

LOSS: \$13.54M

T+11h

ROUND 5/5



Simulation — CISO Decisions

- HQ - Milan, Italy (Finance doing on ERP)
- Sales - New York, USA (CRM/reporting offline)

****ADDITIONAL LOSS:** \$1.2M (lost sales opportunities, delayed invoicing, compliance reporting gaps)**

****HOURS ELAPSED:** +2 hours (now 10 hours total)**

****TOTAL LOSS SO FAR:** \$9.88M**

ROUND 5 OF 5 - FINAL DECISION

Your VP of Finance is demanding ERP access restored within the hour. Manufacturing is stable but fragile. The attacker's lateral movement has stopped, but you still haven't eliminated their foothold in Berlin.

YOUR OPTIONS:

CHOOSE YOUR ACTION:

- **Restore Finance/Sales access by rerouting through a temporary VPN to Frankfurt**** - Bypasses Barcelona bottleneck but introduces potential security gap if attacker pivots through VPN tunnel
- **Hold the line and keep manufacturing priority for 4 more hours until Berlin rebuild completes**** - Finance misses close deadline, sales hemorrhages deals, but you maintain operational continuity and security posture
- **Bring Berlin IT back online NOW with partial forensics**** - Restores full capacity immediately but risks re-infection if rootkit remnants survive, could restart the entire incident
- **Split the difference: give Finance read-only ERP access via Frankfurt, Sales stays dark**** - Partial appeasement, minimal security risk, but New York loses another day of revenue

[← Abort Simulation](#)

Operation Steel Viper — Debrief

Total loss: \$19.4M (10.6% OPEX) over 14 hours, 4 decision rounds. BCP Grade: C. Key gaps in network segmentation, vendor access, recovery time.

AFTER-ACTION REPORT — CLASSIFIED

Operation Steel Viper — Debrief

Simulation completed in 14 hours over 4 decision rounds

TOTAL LOSS

\$19.4M

% OF OPEX

10.6%

TIME SPAN

14h

BCP GRADE

C

Decision Timeline

- ROUND 1
Immediate failover to Frankfurt DR site and rebuild Berlin from backup – Clean slate approach but 4–6 hour recovery window and potential data loss from last backup point
- ROUND 2
Isolate affected systems
- ROUND 3
Bring Barcelona online first as pivot hub – Use Spain's clean backup connection to Frankfurt to cascade MES access to Asian sites, creates single point of failure
- ROUND 4
Throttle non-critical traffic and implement QoS prioritization – Keeps cascade alive longer but kills BI/reporting access for Finance and Sales

Key Recommendations

- Network Segmentation:** The simulation revealed that lateral movement between the Tech Hub and manufacturing MES links was the primary propagation vector. Implement microsegmentation.
- Vendor Access Controls:** Initial breach was via compromised vendor VPN. Enforce zero-trust architecture with MFA and just-in-time access for third parties.
- BCP Gap — Recovery Time:** Your response took 14 hours. Industry benchmark for ransomware containment is 4–6 hours. Run tabletop exercises quarterly.